

OXOT CYBER DIGITAL TWIN

Before you change and spend, replicate your plant.

OXOT powers better OT security decisions.

We build a working replica of your plant from the engineering documents you already hold, then test attacks and changes against the replica instead of the real thing. What you buy is not the model. What you buy is the ability to decide — with evidence — what to fix, what to spend and what to leave alone.

FOUR DECISIONS THIS MAKES ANSWERABLE

What do we fix first? Findings ranked by what they would actually cost you, not by severity score.	What should we spend? A figure with a ceiling on it, and the point past which more money buys little.	Can we change this safely? Test the firewall, the re-zoning or the patch in the replica before the plant.	What can we ignore? A written, defensible decision to leave alone what cannot reach anything that matters.
--	---	---	--

THE PROBLEM IT ANSWERS

Industrial plants were not built for today's cyber reality.

Ageing equipment, asset records that disagree with each other and ever more connection between the plant and the office make it hard to see where the real risk sits. And unlike office IT, the fix carries risk of its own: improvements have to be made in a live plant where stopping is not an option.

The hard part is not finding security issues.

It is knowing which ones matter, which can safely be changed, and what to do first.



01

See your OT environment

02

Understand the risk

03

Know what to do next

DECISION 01

Three answers, and the discipline to use the third.

Every operator has a backlog too long to finish and no defensible way to order it. We sort findings by what would physically happen if they were used against you, weighed against whether anyone could actually reach them.

How we know: the consequence comes from your own safety and reliability studies, and reachability from a model of your real network. Neither is our opinion.

NOW**COULD END YOU**

Something an attacker can reach that protects life or keeps the plant running. Not a budget conversation.

NEXT**WORTH THE MONEY**

Real exposure you could survive, ordered by how much risk each euro removes.

NEVER**WRITTEN OFF, ON RECORD**

Unreachable, or reachable with no consequence. Documented with the reasoning, so it survives an auditor and a change of staff.

NEVER is the one that changes how a team works.

A backlog of four hundred items stops behaving like an unpriced liability the moment you can say, in writing, which of them cannot hurt you.

WHAT YOU ARE LEFT HOLDING

One number for the board

The Consequence Index — a single organisational rating, priced in euros, trended over 90 days, that drills all the way back down to the component that caused it.

A cost, not a score

Expected annual loss in euros, with the rare severe outcome priced separately from the ordinary year — grounded in published breach and claims data.

Nothing you cannot take apart

Every figure traces to the evidence that produced it, and every outside source is cited beside the value it fed. Never underwrite a number you cannot open.

WHAT CHANGES, AND FOR WHOM

The board

Stops being asked to trust a maturity score, and starts seeing one figure that moves.

Engineering

Gets a queue for Monday that survives a challenge from the plant manager.

Procurement

Buys against a number, and can compare two proposals on the same basis.

Audit and insurers

See the reasoning, not just the conclusion — including what was deliberately not done, and why.

REPORTED AS A 90-DAY TREND, AND IT MOVES FOR THREE REASONS

You changed something — work completed, and the risk it removed

The plant changed — new equipment, drift, an undocumented alteration

The world changed — a new exploit, a supplier, a shift in conditions

DECISION 02

What should we spend, and what does it buy us?

Security spend does not reduce risk in a straight line. The first investments compound; then the curve flattens, and past a point more money buys almost nothing. We map that curve for your estate and find the ridge — where each additional euro returns the most, and where it stops paying.

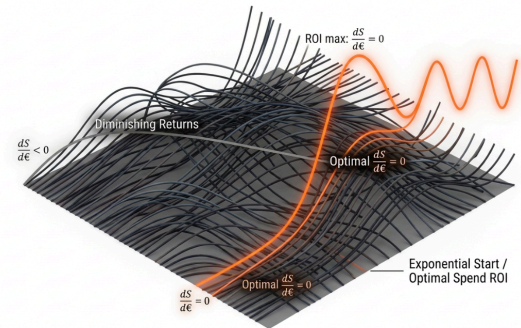
That is the difference between a quantified risk and an actionable one: a recommendation with a ceiling on it rather than an open-ended ask.

THE RARE SEVERE YEAR, PRICED ON ITS OWN

Industrial cyber loss is fat-tailed: one attacker reaching one safety-critical system produces a loss far beyond the average, and averaging never surfaces it. Monte Carlo simulation returns a full range of outcomes with confidence intervals, and the conditional value at risk of the tail is stated apart from the central estimate.

Survive first. Optimise second.

A programme that lowers average risk while leaving the ruinous case intact has spent money and bought nothing.



Risk reduction against spend: exponential start, ROI ridge, then diminishing returns.

WHAT THE RIDGE GIVES YOU

A bounded number

A spend recommendation with a stated ceiling, and the point beyond which more money stops paying.

Comparable options

Competing controls, vendors and sequencing scored against the same set of outcomes, so the comparison is like for like.

A roadmap that orders itself

Every finding carries the risk it removes per euro, so the sequence falls out of the model rather than out of a workshop.

WHERE THE EURO FIGURE COMES FROM

Every term traces to a published source rather than an internal assumption, and the citation is stored beside the value — so an actuary, an underwriter or a CFO can pull any figure apart.

How often — incident frequency for your sector, from published breach investigations

How much — loss size by sector and company size, from published insurance claims studies

It really happened — disclosed corporate filings, as anchors on the scale

Where you are — governance, conflict and economic conditions around each site

Who is active — the groups currently targeting your sector

WHAT WE DO NOT CLAIM

These are our own transparent calculations, not an actuarial or rating-agency mark

Directionally validated on real engagements, and stated with confidence intervals rather than as a single number

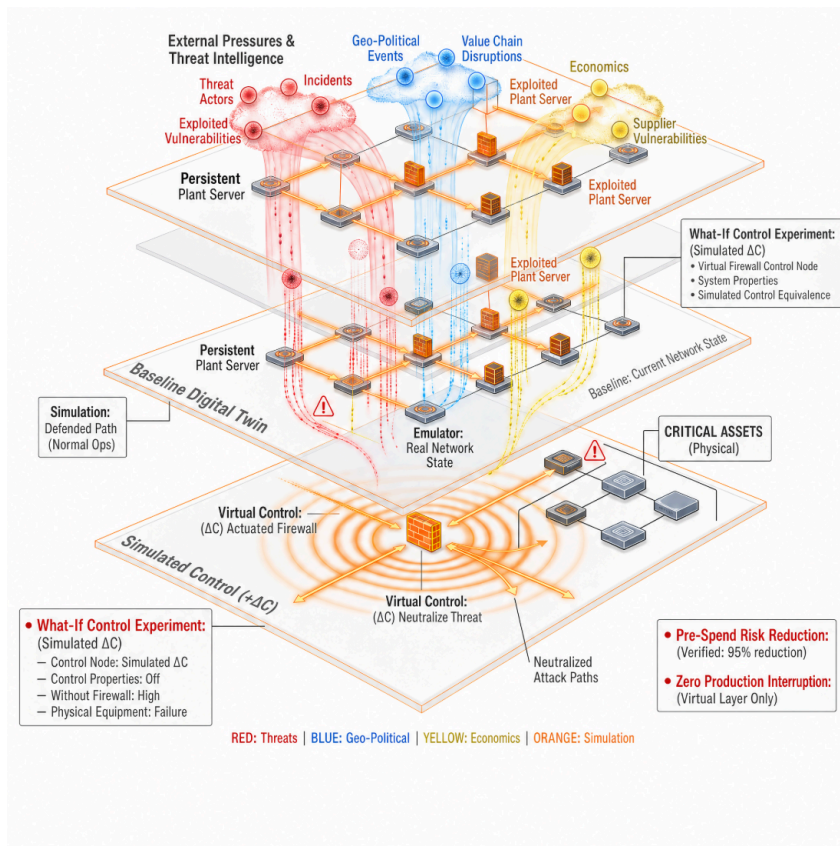
Insurers price the loss. The twin is built to lower it — the same model that produces the number shows which change moves it.

DECISION 03

Buy the control after you have watched it work.

Because the twin is a model, you change it before you change the plant. Add the firewall virtually, redraw the segmentation, apply the patch campaign — then re-run the attacks and compare the results. The difference between them is the risk that control actually buys.

Nothing touches production, and the number arrives before the purchase order does.



HOW THE EXPERIMENT RUNS

Four layers, read downward. Every one of them is a change to the model, never to the plant.

Baseline

The plant as it is, with the routes an attacker could really take to a critical asset.

Pressure applied

Attackers, known exploits, geopolitics and supplier exposure — as inputs, not reports.

The candidate control

Placed in the model only. You see which routes it closes, and which it misses.

Before you spend

The reduction is quantified before procurement, and production is never touched.

WHAT YOU CAN TEST

Capital purchases

Score competing products and vendors against the same outcomes before the order is placed.

Configuration changes

Segmentation, firewall rules and patch campaigns rehearsed in the model rather than in the plant.

Drift and accidents

The change nobody logged, and three quiet years of it. The same simulation explores what could already have gone wrong.

WHY THE ANSWERS HOLD

Consequence first, then reachability, then a price.

Most of the industry works backwards: start from a vulnerability score, then guess at the impact. Consequence has to come first, because it is the only part that is genuinely knowable — the engineering already tells you what happens when a specific thing fails, and which safety system is supposed to catch it.

Probability is then a question about routes through your network. Price is arithmetic.

STEP 01 Consequence What physically happens, and what stops running.	STEP 02 Pathway Whether anyone can actually get there from outside.	STEP 03 Probability How likely that is, stated with confidence intervals.	STEP 04 Financial impact Consequence times probability, in euros.
--	---	---	---

THE LOSS IS ENGINEERED, NOT ESTIMATED

How much a failure costs is not something a security tool should be guessing at. Your own engineers have already worked it out and signed it off. We use their figures rather than inventing our own.

Safety studies (FMECA) — how each component fails and what follows
Reliability-critical items — lost production and lost product quality
Safety-critical items — mapped to the systems meant to protect them
Minimum operating requirements — what has to keep running, and for how long
A cyber route inherits the cost the engineering already carries. Nothing is invented at the security layer.

A ROUTE, NOT A SEVERITY NUMBER

Every asset is checked against what is known about the flaws it carries — and then scored by whether an attacker could reach it through your actual network. A critical flaw on an unreachable asset is not a critical risk.

Known to be exploited — flaws attackers are using right now (KEV)
Likelihood of exploitation — how probable an attempt is (EPSS)
Technical severity — how bad it is if used, in context (CVSS)
Attacker methods — the techniques that fit that route (MITRE ATT&CK)
Reachability is decided by the model of your network, not by a scanner's opinion.

A worked example

ILLUSTRATIVE

A dosing controller on a treatment line is running firmware with a flaw attackers are known to be using.

CONSEQUENCE The dose can leave its safe band, with one safety system catching it. A lost shift and a reportable quality event.	PATHWAY It sits in a zone reachable from the maintenance network, which a vendor laptop dials into.	PROBABILITY With that route open and the flaw in active use, a successful reach sits high in the range.	DECISION NOW — and brokering the vendor route closes it for far less than replacing the controller.
--	---	---	--

WHAT WE WATCH FOR YOU

Risk does not stop at the fence line.

Every facility sits somewhere, and where it sits changes what can happen to it. We track threat activity, political and economic conditions, military events and environmental risk across nine areas, and bind them to each site's real location.

These are inputs to the model, not a separate report on a different desk. Your exposure can change on a Tuesday when nothing inside the fence was touched.

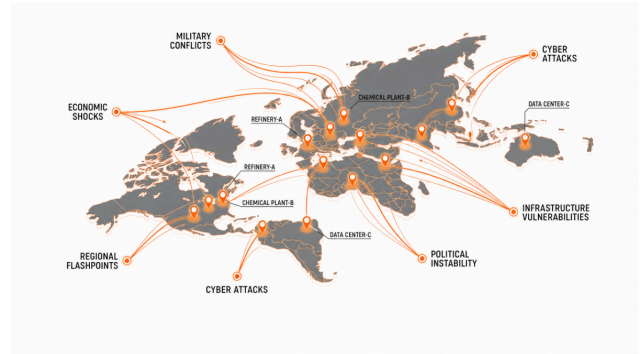
COUNTRY AND KNOCK-ON EFFECTS

31-country instability index — governance, stability and conflict signals, refreshed as conditions change

Knock-on failure analysis — how an outage somewhere else reaches your operation

Value chain — the partners you depend on, upstream and downstream; their outage is your outage

Supplier rating — vendors and products scored on their track record, for procurement



External pressure bound to each site's real location.

NINE AREAS MONITORED

News & geopolitics	Military & security	Maritime & aviation
Cyber & infrastructure	Climate & disasters	Energy & commodities
Finance & economy	Government & supply chain	Nuclear & strategic facilities

WHO IS COMING, AND WITH WHAT

Attacker profiles (ATQ) — capability, motivation, and how dangerous each group is to a plant like yours

Threat fingerprints (TACAM) — methods, target sectors, geography, plant protocols, timing, vendor products and weakness types

Crossed together, these answer which groups target your sector using your vendors' equipment.

WHAT THIS CHANGES

Risk becomes site-specific — two identical plants in different countries do not carry identical risk

Leading, not lagging — the forecast moves before an incident, not after one

Procurement carries evidence — supplier history is attached to the buying decision, not discovered after installation

External pressure supplies the likelihood. Your own engineering supplies the cost. The twin is where the two meet.

HOW THIS ENTERS THE MODEL

On a schedule, not on request

Sources refresh on their own cadence and everything downstream recomputes in order — current without anyone asking.

Bound to each site

Conditions attach to real locations, so a plant inherits the pressure around it, not an average.

Every change is a difference

Each refresh is recorded against the state before it, with the movement in risk attached.

THE ENGINE

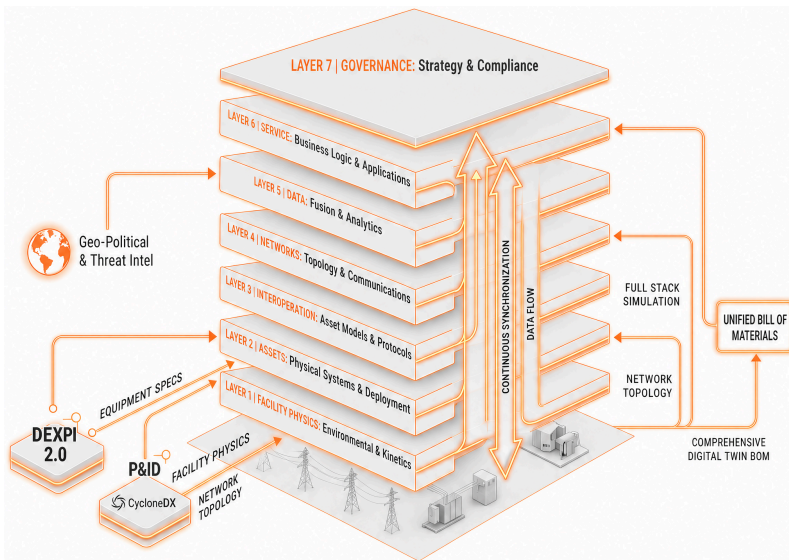
You cannot defend what you have never modelled.

Everything on the previous pages rests on one thing: a living, queryable model of your plant — every asset, every flow, every dependency — assembled from documents you already hold and kept in step with the plant as it changes.

It is built from the ground up, in the order the plant itself was built. Layer one is not a firewall — it is physics — which is why a finding is measured in production, safety and euros rather than in severity.

SEVEN LAYERS, FOUR MOVEMENTS

Each layer holds what the layer beneath it cannot explain about itself. Read from the bottom, the model moves from what is physically true, through how the plant communicates, to what it means and what you do about it.



Ground L1-L2

Physics, then the controllers and equipment acting on it.

Connect L3-L4

The protocols the plant speaks, and the network they cross.

Interpret L5-L6

Threats and conditions fused, and the services built on them.

Decide L7

Risk, what-if, compliance — the pages you just read.

In: your P&IDs, equipment specifications, network drawings and asset registers. **Out:** one synchronised parts list across all seven layers.

ONE MODEL, MANY VIEWS

P&ID	Zones	Network	Graph	3D
The plant as drawn, carrying cyber state	Standard plant layering, with security levels	Real topology, not the intended design	What depends on what, several levels deep	Spatial context for the people who walk to it

BOTH DIRECTIONS

component → equipment → line → facility → organisation

From the board's single figure down to one firmware version, or from one component up to what it costs the group.

A COMPLETE PARTS LIST

<> Software Down to the individual library	⚙️ Hardware Devices and the firmware on them	🔒 Cryptography Including quantum-era exposure	☁️ Cloud services What the estate depends on externally	🌞 Operations How the plant is actually run
--	--	---	---	--

Machine-readable, versioned and comparable between dates, with indirect dependencies traced — so a flaw five libraries deep still surfaces, and regulatory files are generated rather than written.

DEPLOYMENT — THREE OPTIONS, ALL PASSIVE-FIRST

Nothing is installed on your controllers and the process network is never actively scanned, in any configuration.

OPTION 01**Island mode**

Isolated. On your own ground, no external dependencies. No access to control systems. Your own custom AI model.

OPTION 02**One-way data diode**

A data diode limits data to inbound only. This allows our intelligence to stream into the Cyber Digital Twin, but nothing exits.

OPTION 03**Dedicated instance**

A single-tenant instance located in an AWS service of your choice, aligned to your data sovereignty requirements.

ENGAGEMENT

OXOT OT engineering consultants build and deploy the Cyber Digital Twin. Both models are consulting-led — this is not software you install alone.

Transient — one-time consulting services, built and handed over

Long-term operations — the twin sustained alongside the estate as it changes

We integrate with asset management, historians, network monitoring and service management applications.

COMPLIANCE, FROM THE SAME MODEL

The standards are the model's own structure rather than an appendix to it, so the evidence is a generated view of work you were already doing.

IEC 62443 • TS 50701 — zones and conduits, target and achieved security levels

NIS2 — risk picture and supplier dependency view

Cyber Resilience Act • AI Act • Machine Act — the technical file and the rest, generated

WHERE THE ENGINE CAME FROM

The Cyber Digital Twin was born from delivering acquisition due diligence on a deal clock: whole industrial estates assessed properly, in weeks, without walking every site. That constraint produced the OXOT Seldon Engine — and it is why every engagement starts from a model rather than a checklist.

WHO BUILDS IT

OXOT is a Dutch OT cybersecurity company for the industries that cannot afford to stop, staffed from process and control engineering, industrial networks and safety.

The Dutch government and the European Cybersecurity Competence Centre co-invested in our Cyber Digital Twin under CIF-NL 2025.

Reading this as an engineer or architect? Ask for the **OXOT Cyber Digital Twin Specification Sheet** — the same product described in full technical detail, including protocols, standards mapping, scoring method and platform interfaces.

One environment. One evolving model. Better security decisions.

Bring one P&ID and an asset list for a single facility, and we will build the model and show you what it finds.

Talk to OX — info@oxot.nl

The Consequence Index, expected annual loss and simulations are OXOT's own transparent, drillable calculations, directionally validated on real engagements — not rating-agency or actuarial marks. Sample figures are illustrative, not customer data.